

Security+ 4.5 · Operating System Security

Mestre CyberSec · Aula 4.5 — Operating System Security (3:22) · [Assistir Vídeo no YouTube](#) ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: AD (Active Directory: contas/group/GPO do Windows); Group Policy (deploy de política em massa); SELinux (MAC no Linux — cada processo só o que precisa); patch baseline; disable contas orfãs.

💡 Highlights que a prova CompTIA cobra

- Active Directory: o diretório corporativo Windows
- SELinux: MAC no Linux (mais rigoroso que root)

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'centralized identity management in Windows'=Active Directory

Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 4.5 — Operating System Security)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Active Directory (AD)

Serviço de diretório centralizado da Microsoft que gerencia usuários, grupos, computadores e recursos em um ambiente de domínio Windows através de um banco de dados hierárquico.

⚠ **Armadilha CompTIA:** *If the question mentions 'centralized identity management in Windows' or 'single sign-on for corporate resources' — the answer is Active Directory. Do NOT confuse with LDAP, which is only the protocol AD uses.*

• Objeto de Política de Grupo (GPO)

Uma coleção de configurações de segurança e configuração que podem ser aplicadas em massa a usuários e computadores dentro de um domínio Active Directory.

⚠ **Armadilha CompTIA:** *Exam trigger: 'deploy password policies or restrictions to many machines in a Windows domain' = GPO. GPO works ONLY with AD — without AD, there is no GPO.*

• SELinux (Linux com Segurança Aprimorada)

Um módulo de segurança do kernel Linux que implementa Controle de Acesso Mandatário (MAC), restringindo cada processo apenas às permissões mínimas necessárias.

⚠ **Armadilha CompTIA:** *Exam trigger: 'MAC on Linux' or 'process-level least privilege beyond root' = SELinux. Do NOT confuse with AppArmor (also Linux MAC, but different framework — Debian/Ubuntu default).*

• Controle de Acesso Mandatário (MAC)

Modelo de controle de acesso onde o sistema operacional impõe permissões com base em rótulos e políticas de segurança — o usuário não pode alterar permissões, nem mesmo como root.

⚠ **Armadilha CompTIA:** *MAC vs DAC: in DAC the owner decides; in MAC the OS/admin policy decides. SELinux = MAC, NTFS permissions = DAC. Exam always tests this distinction.*

• Baseline de Patches (N/A)

Conjunto documentado de atualizações aprovadas e padrões de configuração que define a postura mínima de segurança que todos os sistemas devem atender antes de entrar em produção.

⚠ **Armadilha CompTIA:** *Exam trigger: 'minimum configuration standard for new systems' or 'reference point for vulnerability scanning' = patch baseline. Often paired with CIS/NIST benchmarks on the exam.*

• Conta Órfã (N/A)

Conta de usuário não utilizada que permanece ativa após o funcionário ter saído da organização, criando um risco de segurança se for comprometida por atacantes.

⚠ **Armadilha CompTIA:** *Exam answer is ALWAYS 'disable or remove'. Never leave orphaned accounts active. Triggers: 'former employee', 'unused account', 'access review' — best practice is disable first, then delete.*

• Controle de Acesso Discrecionário (DAC)

Modelo de controle de acesso onde o dono do recurso decide quem tem permissões — modelo padrão usado nas permissões de arquivo Linux/Windows e NTFS.

⚠ **Armadilha CompTIA:** *Trigger: 'owner controls permissions' = DAC. NTFS permissions and chmod are DAC. If the question mentions 'the system enforces permissions regardless of owner' — that's MAC.*

• Protocolo Leve de Acesso a Diretório (LDAP)

Protocolo usado para consultar e gerenciar serviços de diretório, como o Active Directory, para autenticação centralizada e buscas de recursos.

⚠ **Armadilha CompTIA:** LDAP is the protocol; Active Directory is the directory service that USES LDAP. Secure version = LDAPS (port 636). Do not answer 'AD' when the question specifically asks about the protocol.

✓ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Durante uma revisão trimestral de acessos em um hospital, a equipe de segurança descobre 14 contas de usuário do Active Directory pertencentes a prestadores de serviço cujos contratos terminaram há mais de 90 dias. As contas ainda estão habilitadas e permanecem em grupos privilegiados. A gerência quer reduzir imediatamente o risco relacionado a identidades. Qual ação a equipe de segurança deve tomar **PRIMEIRO**?

- A) Redefinir as senhas das contas e exigir autenticação multifator no próximo logon.
- B) Desabilitar as contas, remover suas associações a grupos privilegiados e preservá-las para retenção de auditoria conforme a política.
- C) Converter as contas em contas de serviço compartilhadas para tarefas administrativas do departamento.
- D) Mover as contas para uma nova OU e aplicar uma GPO que as oculte da lista de endereços.

QUESTÃO 2 · CENÁRIO DE EXAME

Uma empresa com 1.200 estações de trabalho Windows precisa impor bloqueio de tela após 10 minutos de inatividade e exigência de senha de 12 caracteres para todos os usuários de domínio. Os administradores querem que as configurações sejam aplicadas de forma consistente e automática, inclusive em novos computadores. Qual solução **MELHOR** atende ao requisito?

- A) Configurar a Política de Segurança Local em cada estação de trabalho apenas durante a criação da imagem.
- B) Implantar um script de logon que altera o registro no primeiro logon de cada usuário.
- C) Habilitar o modo enforcing do SELinux nos controladores de domínio.
- D) Criar e vincular um Objeto de Política de Grupo ao domínio ou às OUs apropriadas.

QUESTÃO 3 · CENÁRIO DE EXAME

Um servidor web Linux hospeda vários sites públicos. Após a divulgação de uma vulnerabilidade no serviço web, a equipe de segurança quer limitar os danos caso o serviço seja explorado, de modo que o processo httpd possa acessar apenas seu conteúdo web e as portas de rede necessárias, mesmo que um invasor obtenha execução de código. Qual controle de segurança **MELHOR** atende a esse requisito?

- A) Configurar o SELinux no modo enforcing com uma política targeted e contextos de arquivo/booleans corretos.
- B) Definir as permissões do diretório de conteúdo web como 777 para que o processo não falhe.
- C) Implementar controle de acesso discricionário tornando a conta do serviço web proprietária de todos os arquivos.
- D) Usar iptables para permitir apenas tráfego de entrada TCP 80 e 443 para o servidor.

QUESTÃO 4 · CENÁRIO DE EXAME

Uma organização tem 300 servidores Windows. A aplicação de patches é inconsistente: alguns servidores instalam atualizações automaticamente, outros estão meses atrasados, e administradores aprovam atualizações manualmente de formas diferentes por equipe. Os auditores exigem uma lista padronizada de patches aprovados e um processo de implantação repetível. Qual ação MELHOR estabelece uma linha de base de patches?

- A) Habilitar atualizações automáticas em todos os servidores e deixar cada administrador reiniciar quando for conveniente.
- B) Criar uma GPO que desabilite o Windows Update em todos os servidores para impedir patches não aprovados.
- C) Definir uma linha de base de patches aprovada em uma plataforma central de gerenciamento e implantá-la em grupos de servidores conforme um cronograma.
- D) Executar um script semanal que baixa todas as atualizações disponíveis e as instala sem testes.

QUESTÃO 5 · CENÁRIO DE EXAME

O departamento financeiro usa uma pasta compartilhada em um servidor de arquivos Windows. Atualmente, cada funcionário do financeiro é adicionado individualmente na ACL da pasta, e quando alguém muda de função, permissões frequentemente permanecem. A equipe de segurança quer simplificar a administração e impor privilégio mínimo com base na função. O que eles devem fazer?

- A) Criar um grupo de segurança do AD para o financeiro, atribuir permissões de pasta ao grupo e gerenciar a associação de usuários.
- B) Criar um grupo de distribuição do AD para o financeiro e atribuir permissões de pasta ao grupo.
- C) Colocar todos os usuários do financeiro no grupo Domain Admins e então remover suas entradas ACL individuais.
- D) Configurar uma GPO que mapeie a pasta compartilhada para todos os usuários autenticados.

QUESTÃO 6 · CENÁRIO DE EXAME

Um aplicativo de RH personalizado precisa autenticar funcionários no Active Directory da empresa. A política de segurança proíbe armazenar senhas de funcionários no banco de dados do aplicativo e exige que a desabilitação centralizada de contas tenha efeito imediato. Qual abordagem de integração MELHOR atende a esses requisitos?

- A) Criar contas locais no aplicativo e sincronizar senhas noturnamente a partir do Active Directory.
- B) Armazenar hashes de senha do Active Directory em um arquivo texto acessível ao aplicativo.
- C) Exigir que os usuários entrem com uma conta de aplicativo compartilhada gerenciada pela equipe de RH.
- D) Configurar o aplicativo para autenticar usuários por meio de consultas/binds LDAP(S) ao Active Directory.

QUESTÃO 7 · CENÁRIO DE EXAME

Uma empresa quer bloquear dispositivos USB de armazenamento em massa nos computadores usados pelo departamento financeiro, mas permitir teclados e mouses USB. Os computadores do financeiro estão em uma OU dedicada, e a empresa usa sistemas Windows ingressados no domínio. Qual método é MAIS eficiente e aplicável?

- A) Colocar cola física em todas as portas USB dos computadores do financeiro.
- B) Criar uma GPO vinculada à OU do financeiro que desabilite o acesso a armazenamento removível.
- C) Aplicar uma política de segurança local em cada computador do financeiro e pedir aos usuários que não conectem drives.
- D) Configurar booleans do SELinux nas estações do financeiro para negar armazenamento USB.

QUESTÃO 8 · CENÁRIO DE EXAME

Em um servidor Linux, desenvolvedores são proprietários de arquivos em um diretório compartilhado de projeto. A segurança descobre que um desenvolvedor pode alterar permissões de um arquivo sensível e conceder leitura a outros usuários, mesmo que o arquivo contenha dados regulamentados. A equipe de segurança quer que o sistema operacional imponha regras de acesso que proprietários de arquivos não possam sobrepor. Qual controle MELHOR fornece isso?

- A)** Permissões padrão de controle de acesso discricionário do UNIX.
- B)** Listas de controle de acesso que concedem propriedade ao desenvolvedor.
- C)** Uma política de controle de acesso obrigatório do SELinux.
- D)** Uma regra sudoers permitindo que desenvolvedores gerenciem permissões de arquivos.

QUESTÃO 9 · CENÁRIO DE EXAME

Uma auditoria em um servidor Linux de aplicação encontra uma conta de serviço local chamada appsvc. O aplicativo que ela suportava foi desativado há seis meses, mas a conta ainda tem senha válida, uma chave SSH autorizada e shell Bash. Qual ação o administrador deve tomar para reduzir o risco?

- A)** Alterar a senha e armazená-la no cofre de senhas da equipe para uso futuro.
- B)** Adicionar a conta ao arquivo sudoers para que futuros administradores possam solucionar problemas.
- C)** Alterar o UID da conta e deixar seus arquivos inalterados.
- D)** Bloquear a conta, remover suas chaves SSH, definir o shell como nologin e excluí-la se não houver dependência.

QUESTÃO 10 · CENÁRIO DE EXAME

Um servidor crítico de manufatura executa um aplicativo certificado pelo fornecedor. O fornecedor não certificou a atualização de segurança mais recente, mas a linha de base de patches da organização a exige. O servidor não pode ser desligado para testes neste trimestre. O que a equipe de segurança deve fazer?

- A)** Documentar uma exceção temporária, aplicar controles compensatórios e rastrear o servidor em um grupo de patches separado até a certificação do fornecedor.
- B)** Remover o servidor de toda aplicação de patches e monitoramento porque ele não pode ser atualizado.
- C)** Aplicar a atualização imediatamente sem testes e aceitar qualquer indisponibilidade do aplicativo.
- D)** Desabilitar o firewall do servidor para que o fornecedor possa aplicar remotamente um patch não aprovado.

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa B — Desabilitar as contas, remover suas associações a grupos privilegiados e preservá-las para retenção de auditoria conforme a política.

Correta: Contas órfãs são risco grave porque permanecem habilitadas e privilegiadas depois que o usuário não deveria mais ter acesso. A primeira ação é desabilitá-las e remover associações a grupos privilegiados, preservando-as apenas conforme exigido para auditoria. Redefinir senha as mantém habilitadas; converter em conta compartilhada prejudica responsabilização; ocultar da lista não remove acesso.

Questão 2: Alternativa D — Criar e vincular um Objeto de Política de Grupo ao domínio ou às OUs apropriadas.

Correta: Objetos de Política de Grupo implantam e aplicam centralmente configurações de segurança do Windows em sistemas ingressados no domínio e podem ser aplicados a novos computadores colocados no domínio ou na OU vinculada. Política de Segurança Local afeta apenas a máquina local e pode não cobrir novos sistemas de forma confiável; scripts de logon são menos confiáveis e não são política de segurança real; SELinux é um mecanismo de controle de acesso obrigatório no Linux, não uma ferramenta de política AD no Windows.

Questão 3: Alternativa A — Configurar o SELinux no modo enforcing com uma política targeted e contextos de arquivo/booleans corretos.

Correta: SELinux é um sistema de controle de acesso obrigatório no Linux que confina processos como o httpd a tipos/domínios declarados e limita o que eles podem acessar mesmo após comprometimento. Definir permissões como 777 aumenta o risco; tornar a conta de serviço proprietária ainda é controle discricionário e amplo; iptables filtra tráfego de rede, mas não confina o acesso a arquivos e processos de um processo comprometido.

Questão 4: Alternativa C — Definir uma linha de base de patches aprovada em uma plataforma central de gerenciamento e implantá-la em grupos de servidores conforme um cronograma.

Correta: Uma linha de base de patches é um conjunto documentado de patches e configurações aprovados usado pelo gerenciamento central para implantar atualizações de forma consistente. Atualizações automáticas por servidor causam inconsistência; desabilitar o Windows Update impede correções de segurança; instalar todas as atualizações sem testes viola o controle de mudanças e pode interromper serviços.

Questão 5: Alternativa A — Criar um grupo de segurança do AD para o financeiro, atribuir permissões de pasta ao grupo e gerenciar a associação de usuários.

Correta: Grupos de segurança do AD são projetados para atribuição de permissões e simplificam o controle de acesso baseado em função. Grupos de distribuição são para e-mail e não podem ser usados para permissões de segurança; Domain Admins concede privilégio excessivo; mapear a pasta para todos os usuários autenticados concede acesso amplo demais.

Questão 6: Alternativa D — Configurar o aplicativo para autenticar usuários por meio de consultas/binds LDAP(S) ao Active Directory.

Correta: LDAP(S) permite que o aplicativo consulte e autentique no Active Directory sem armazenar senhas de funcionários. Sincronização noturna de senhas atrasa a desabilitação centralizada e armazena credenciais; armazenar hashes de senha é inseguro; uma conta de aplicativo compartilhada quebra a responsabilização e não impõe desabilitação centralizada imediata por usuário.

Questão 7: Alternativa B — Criar uma GPO vinculada à OU do financeiro que desabilite o acesso a armazenamento removível.

Correta: Uma GPO vinculada à OU do financeiro aplica centralmente restrições de dispositivo para todos os computadores atuais e futuros naquela OU. Cola física é impraticável e afeta todos os dispositivos USB; política local não é aplicada centralmente; SELinux é um controle Linux, não um mecanismo de política para estações Windows de domínio.

Questão 8: Alternativa C — Uma política de controle de acesso obrigatório do SELinux.

Correta: O controle de acesso obrigatório do SELinux impõe política independentemente da propriedade de arquivo e do DAC, então mesmo um proprietário não pode sobrepor negações do SELinux. Permissões UNIX padrão e ACLs são controles de acesso discricionário; uma regra sudoers aumenta a capacidade do desenvolvedor de alterar permissões.

Questão 9: Alternativa D — Bloquear a conta, remover suas chaves SSH, definir o shell como nologin e excluí-la se não houver dependência.

Correta: Esta é uma conta local órfã com credenciais ativas. A boa prática é remover o acesso bloqueando-a, removendo chaves SSH, definindo um shell não interativo e excluindo-a se não houver dependência. Manter a senha, adicionar privilégios sudo ou alterar o UID deixa caminhos de acesso e viola o privilégio mínimo.

Questão 10: Alternativa A — Documentar uma exceção temporária, aplicar controles compensatórios e rastrear o servidor em um grupo de patches separado até a certificação do fornecedor.

Correta: Quando uma linha de base de patches não pode ser aplicada, a gestão formal de exceções com controles compensatórios e rastreamento é apropriada até que o fornecedor certifique a atualização. Remover patches e monitoramento aumenta o risco; aplicar uma atualização não testada pode interromper a manufatura crítica; desabilitar o firewall é inseguro.